

Plano de Aula — Autenticação e Autorização

1. Identificação

Professor: Henry Emanuel Leal Cagnini

Disciplina: Engenharia De Software II

Curso: Sistemas para Internet

Tema da aula: Autenticação e Autorização

Modalidade: Seminário

Apresentadores: Lorenzo dos Reis, Arthur Novak e Andrei Cecatto

2. Ementa

Conceitos fundamentais de segurança em aplicações e sistemas Web. Autenticação e verificação de identidade. Fatores de autenticação e autenticação multifator (MFA). Métodos modernos de autenticação, incluindo TOTP, biometria e passkeys. Conceitos de autorização e controle de acesso. Modelos RBAC, ABAC e ACL. OAuth 2.0 e OpenID Connect. Estrutura e funcionamento de tokens JWT. Principais falhas relacionadas à autenticação e ao controle de acesso e boas práticas de segurança.

3. Público-alvo e pré-requisitos

A aula é direcionada aos alunos do curso de **Sistemas para Internet**, especialmente estudantes que já possuem conhecimentos básicos sobre desenvolvimento de aplicações Web e funcionamento de sistemas computacionais.

Como pré-requisito, espera-se que os alunos tenham conhecimentos introdutórios sobre aplicações Web, usuários, sistemas de login e acesso a recursos. Não é necessário conhecimento prévio aprofundado sobre mecanismos específicos de autenticação ou autorização, pois esses conceitos serão apresentados e desenvolvidos durante o seminário.

O tema está relacionado diretamente ao desenvolvimento e à segurança de sistemas Web, permitindo que os conceitos apresentados sejam associados a situações presentes no desenvolvimento de aplicações.

4. Objetivos

Esta aula tem como objetivo apresentar aos alunos os conceitos fundamentais de **autenticação e autorização**, demonstrando sua importância para a segurança de aplicações e sistemas Web.

Ao final da aula, espera-se que o aluno seja capaz de:

- Compreender a diferença entre **autenticação** e **autorização**;
- Identificar os principais fatores de autenticação;
- Compreender o funcionamento da autenticação multifator (MFA);
- Reconhecer métodos modernos de autenticação, como TOTP, biometria e passkeys;

- Conhecer os principais modelos de controle de acesso, como RBAC, ABAC e ACL;
- Compreender de forma introdutória o funcionamento do OAuth 2.0, OpenID Connect e JWT;
- Identificar falhas comuns relacionadas à autenticação e ao controle de acesso;
- Reconhecer boas práticas para tornar aplicações mais seguras.

5. Duração

A aula terá duração entre 1 hora e 20 minutos e 2 horas.

6. Conteúdos abordados

Os conteúdos serão organizados em três partes.

1. Autenticação

- Conceito de autenticação;
- Identificação, verificação e sessão;
- Fatores de autenticação:
 - Conhecimento;
 - Posse;
 - Inerência;
- Autenticação multifator (MFA);
- Senhas com hash e salt;
- TOTP;
- Biometria;
- Passkeys e WebAuthn.

2. Autorização

- Diferença entre autenticação e autorização;
- Códigos HTTP 401 e 403;
- Modelos de controle de acesso:
 - RBAC;
 - ABAC;
 - ACL;
- OAuth 2.0;
- OpenID Connect;
- Access Token e ID Token;
- Estrutura de um JWT.

3. Segurança na prática

- Quebra de controle de acesso;
- IDOR;
- Falhas de identificação e autenticação;
- Credenciais vazadas;
- Ausência de limite de tentativas de login;
- Expiração e revogação de sessões/tokens;
- Boas práticas de segurança;
- Zero Trust;

- Passwordless.

7. Metodologia

A aula será desenvolvida utilizando uma abordagem **expositiva e participativa**, combinando a apresentação dos conceitos teóricos com situações práticas relacionadas ao desenvolvimento de aplicações Web.

A organização da aula será dada da seguinte forma:

Parte teórica

- Apresentação inicial do tema;
- Introdução à segurança de aplicações Web;
- Apresentação do conceito de autenticação;
- Explicação dos fatores de autenticação e MFA;
- Apresentação dos principais métodos modernos;
- Diferenciação entre autenticação e autorização;
- Apresentação dos modelos RBAC, ABAC e ACL;
- Explicação introdutória sobre OAuth 2.0, OpenID Connect e JWT;
- Apresentação de falhas comuns e boas práticas.

Parte prática/interativa

Atividade Prática Desplugada

A atividade prática será realizada em duplas, com duração aproximada de 10 minutos, sem a necessidade de utilização de computadores. Os alunos assumirão o papel de analistas de segurança e deverão observar diferentes telas do sistema acadêmico **UniSystem**, identificando falhas relacionadas à autenticação, autorização e sessão.

Será disponibilizado aos alunos um material impresso contendo as telas do sistema e uma tabela para registro das evidências encontradas. Para cada falha identificada, os alunos deverão registrar em que tela ela foi observada e explicar o que ela permite que um atacante faça. Ao todo, deverão ser encontradas **13 falhas** presentes no cenário apresentado.

A atividade tem como objetivo exercitar, de forma prática e desplugada, a identificação de problemas de segurança em um sistema, a partir da análise de situações apresentadas visualmente.

8. Recursos Didáticos

Para a realização da aula serão utilizados:

- Computador para reprodução da apresentação;
- Slides sobre Autenticação e Autorização, utilizados como apoio durante a exposição do conteúdo;

- Materiais impressos ou disponibilizados aos alunos para a realização de uma atividade desplugada;

Durante a aula, os conteúdos serão apresentados por meio dos slides projetados, utilizados como recurso visual para auxiliar na explicação dos conceitos de autenticação, autorização e segurança. Ao final da exposição, será realizada uma **atividade desplugada**, na qual os alunos poderão aplicar os conceitos apresentados sem a necessidade de utilizar computadores ou outros dispositivos.

9. Avaliação dos alunos

A avaliação será realizada de maneira **formativa**, considerando principalmente a participação dos alunos durante a aula e a compreensão dos conceitos apresentados.

Serão considerados:

- Participação durante a aula;
- Progresso na resolução da atividade desplugada passada ao fim da aula.
- Número de acertos nas questões da atividade.

10. Bibliografia

Bibliografia básica

OWASP Foundation. Authentication Cheat Sheet. OWASP Cheat Sheet Series. Disponível em: OWASP Authentication Cheat Sheet. Acesso em: 9 set. 2026.

OWASP Foundation. Authorization Cheat Sheet. OWASP Cheat Sheet Series. Disponível em: OWASP Authorization Cheat Sheet. Acesso em: 9 set. 2026.

— É especialmente relevante para a atividade, pois diferencia autenticação de autorização e aborda controle de acesso, privilégios e acesso indevido a recursos.

OWASP Foundation. OWASP Top 10:2021. OWASP. Disponível em: OWASP Top 10. Acesso em: 9 set. 2026.

Bibliografia complementar

TEMOS HOK, David et al. Digital Identity Guidelines: Authentication and Authenticator Management. NIST Special Publication 800-63B-4. National Institute of Standards and Technology, 2025. Disponível em: NIST SP 800-63B-4. Acesso em: 9 set. 2026.

— É uma referência atual para autenticação, credenciais e gerenciamento de autenticadores.

LODDERSTEDT, Torsten; BRADLEY, John; LABUNETS, Andrii; FETT, Daniel. Best Current Practice for OAuth 2.0 Security. RFC 9700. IETF, 2025. Disponível em: RFC 9700 – OAuth 2.0 Security. Acesso em: 9 set. 2026.

— Útil para contextualizar autenticação/autorização em aplicações modernas, APIs e OAuth 2.0.

JONES, Michael; BRADLEY, John; SAKIMURA, Nat. JSON Web Token (JWT). RFC 7519. IETF, 2015. Disponível em: RFC 7519 – JSON Web Token. Acesso em: 9 set. 2026.